

IR-Pilot - Kurzueberblick

Gefuehrtes Incident-Response-Tool, offline am Smartphone (USB-Stick/PWA). Szenario waehlen → Schritte abarbeiten → Beweise/IOCs/Meldungen erfassen → Bericht exportieren.

IR-Pilot

Neuer Vorfall

Szenario waehlen – startet ein gefuehrtes Playbook.

HOCH

Rechnungs-/IBAN-Manipulation (BEC)
IT · Betrug / E-Mail-Kompromittierung
Versendete Rechnungen kommen mit fremder IBAN an; eingehende PDFs tragen alle dieselbe (auslaendische) IBAN.

KRITISCH

Umspannwerk 300 kV – physischer Einbruch + OT-Manipulationsverdacht
OT/ICS · Energie (KRITIS)
Einbruch ohne Diebstahl/Schaden; Verdacht auf Cyber-Manipulation, ggf. an Schutzgeraeten (Schutzrelais).

KRITISCH

Bahnstellwerk – aktiver Eindringling (Maus bewegt sich)
OT/ICS · Bahn (Safety-kritisch)
Schaltmeister sieht Mauszeiger sich ohne Eingabe bewegen – aktiver Fernzugriff auf einem sicherheitsrelevanten Bedienplatz.

KRITISCH

Ransomware – alles verschluesselt (Kasse, Buero, Klima)
IT/OT · Ransomware
Flaechendeckende Verschluesselung von POS, Buero-IT bis Gebaeude-/Klimasteuerung.

KRITISCH

Active Directory – Brute Force auf Domain-Admin, dann erfolgreich
IT · Identitaet / AD-Kompromittierung
IDS meldet ~400 fehlgeschlagene Logins gegen einen Domain-Admin in der Produktion, danach ein erfolgreicher.

HOCH

Supply-Chain – Wartungslaptop mit Malware (4 MW Solar + 500 kW Speicher)
OT/ICS · Energie / Lieferkette
Lieferant meldet: Laptop des gestrigen Wartungstechnikers hat Malware mit C2 nach Russland.

HOCH

Phishing-Welle – Zugangsdaten abgegriffen
IT · Phishing / Identitaet
Mehrere Mitarbeiter haben auf eine Phishing-Mail geklickt/Zugangsdaten eingegeben; Folgeanmeldungen aus dem Ausland.

KRITISCH

Wasserwerk – Manipulation der Trinkwasser-Steuerung (OT/KRITIS)
OT/ICS · Wasser (KRITIS, Gesundheit)
Auffaellige Sollwerte/Schaltzustaende in der Wasseraufbereitung (z.B. Dosierung/Chlorung) – Verdacht auf Manipulation.

KRITISCH

Cloud/M365 – Tenant-Uebernahme (Global Admin)
Cloud · Identitaet (M365/Entra)
Verdacht auf Uebernahme des M365/Entra-Tenants: neue Global Admins, OAuth-Consent, fremde

Rechnungs-/IBAN-Manipulation (BEC)

TLP:AMBER

Playbook

Beweise

IOCs

Komm.

Tools

Bericht

Organisation

Beispiel GmbH

Responder

IR-Team

Einstufung

TLP:AMBER

12/24 Massnahmen · 50 %

Forensische Ableitung

Symptom: IBAN auf dem Quellrechner korrekt, beim Kunden falsch; eingehende Rechnungen einheitlich manipuliert (z.B. nach Litauen).

Hypothesen: (a) **Man-in-the-Mail / BEC** – Postfach kompromittiert, Weiterleitungs-/Posteingangsregeln, Anhaenge werden im Transit getauscht. (b) **Endpoint-Malware (Banking-Trojan)**, die PDFs beim Erzeugen/Senden manipuliert. (c) Kompromittierter Mailserver/Connector. (d) Tippfehler-Domain / Lieferanten kompromittiert.

Beweis-Ableitung: Header & Audit-Logs des Postfachs, Postfachregeln/Weiterleitungen, Vergleich gesendetes Original vs. zugestelltes PDF, Endpoint-Forensik (Autostarts/Prozesse), Mailflow-/Transport-Logs.

Erstbewertung – Vorfall oder Fehlalarm?

1/4

✓

Erstbewertung & Quelle dokumentieren

Wer meldet **was genau**? Quelle/Verlaesslichkeit, Zeitpunkt, betroffene Systeme. Fakten von Vermutung trennen.

i

Nicht-boeswillige Erklaerung pruefen

Vor "Betrug": pruefen, ob die IBAN-Aenderung **legitim** ist (echte Bankverbindungs-aenderung des Lieferanten, telefonisch ueber bekannte Nummer bestaetigt) oder ein reiner Anzeige-/OCR-Fehler. Erst dann Betrugsfall.

?

Einstufung – Vorfall oder Fehlalarm?

Aufgrund der ersten Fakten einstufen. **Bei Safety-/Versorgungsrisiko trotz Unsicherheit vorsorglich wie einen Vorfall behandeln** (Schutzmassnahmen ja, irreversible Schritte nein).

Bestaetigter Angriff/Vorfall

Verdacht – weiter pruefen

Fehlalarm / kein Angriff

i

Weiter mit dem Playbook

Einstufung bestaetigt mit dem Playbook

Mailregeln/Exfiltration.

Offene Faele

Noch keine Faele.

Einstellung bestaetigt → mit den Phasen unten fortfahren. **Sicherheit und fluechtige Beweise zuerst.**

Identifikation & Sofortmassnahmen

1/4

☐ Zahlungsstopp veranlassen

Sofort intern und bei betroffenen Kunden **vor Zahlungen auf neue/geaenderte IBANs warnen**. Bereits angewiesene Zahlungen pruefen.

☐ Umfang erfassen

Welche Konten/Postfaecher? Seit wann? Welche Kunden/Rechnungen betroffen? Schadenhoehe?

Betroffene Postfaecher / Zeitraum / Schaden

☒ Beweise NICHT veraendern

Verdaechtige E-Mails **nicht loeschen/weiterleiten als Original** – als .eml/.msg mit vollstaendigen Headern exportieren. Original-PDFs (gesendet + zugestellt) sichern.

☐ Verdaechtige Postfachregel/Weiterleitung gefunden?

Posteingangsregeln, Auto-Weiterleitung, delegierte Zugriffe pruefen.

Ja – Postfach kompromittiert

Nein / unklar

Krisenkommunikation & Meldepflichten

2/5

☐ Geschaeftsleitung briefen

Kurzes Lagebild (Was ist passiert, Auswirkung, naechste Schritte, Entscheidungsbedarf). **Keine Schuldzuweisung**. Krisenstab benennen.

Vorlage oeffnen

☒ Bank: IBAN-Rueckruf / Recall

Hausbank des Geschaedigten **und** Empfaengerbank kontaktieren. SEPA-**Recall** der Ueberweisung anstossen (schnell!). Empfaengerkonto melden.

Vorlage oeffnen

☐ Kunden & Lieferanten warnen

Ueber **separaten, verifizierten Kanal** (Telefon, nicht per E-Mail-Antwort) vor falschen IBANs warnen und korrekte Bankdaten bestaetigen.

Vorlage oeffnen

☒ Strafanzeige / Polizei (ZAC)

Zentrale Ansprechstelle Cybercrime (ZAC) der Polizei kontaktieren. Anzeige erstatten.

Asservate fuer die Ermittlung sichern (Chain of Custody)

of Custody!).

[Vorlage oeffnen](#)

☐ **Datenschutz / DSGVO pruefen (72 h)**

Sind personenbezogene Daten betroffen? Falls ja: **Meldung an die Aufsichtsbehoerde binnen 72 h** (Art. 33 DSGVO), ggf. Betroffenenbenachrichtigung (Art. 34). DSB einbinden, Frist im Fall notieren.

[Vorlage oeffnen](#)

Beweissicherung 2/4

☒ **E-Mail-Header & verdaechtige Mails sichern**

Vollstaendige Header der betroffenen Mails exportieren (Tool: **Mail-Header**). Original .eml/.msg sichern, Hash bilden.

[+ Beweis erfassen](#)

☐ **PDF-Diff: gesendet vs. zugestellt**

Gesendetes Original-PDF und das beim Kunden angekommene PDF sichern und vergleichen (Metadaten/Producer/Aenderungsdatum, IBAN-Stelle).

[+ Beweis erfassen](#)

☒ **Postfach-Audit & Regeln exportieren**

M365/Exchange: Audit-Log (UAL), **Inbox-Rules**, Weiterleitungen, Anmeldungen/risikoreiche Sign-ins, OAuth-App-Grants. (Tool: **M365-Triage**).

[+ Beweis erfassen](#)

☐ **Endpoint-Triage des Quellrechners**

Falls Malware-Hypothese: Triage des Rechners, der Rechnungen erstellt (Autostarts, Prozesse, Netz). (Tool: **Windows-Triage**).

[+ Beweis erfassen](#)

Eindaemmung 2/3

☒ **Kompromittierte Konten sichern**

Passwoerter + MFA aller betroffenen/privilegierten Postfaecher zuruecksetzen, **aktive Sessions/Token global invalidieren**, OAuth-Grants pruefen.

☐ **Boesartige Regeln/Weiterleitungen entfernen**

Nach Export (!) verdaechtige Inbox-Rules/Forwardings entfernen, delegierte Zugriffe bereinigen.

☒ **IOCs blockieren**

Empfaenger-IBAN, Absenderadressen, Tippfehler-Domains, Mail-Infrastruktur als IOC erfassen und blockieren (Tab IOCs).

Bereinigung 0/1

☐ Mailflow absichern

SPF/DKIM/DMARC pruefen/haerten, externe-Absender-Banner, Anti-Phishing-Policies schaerfen.

Wiederherstellung & sicherer Wiederanlauf 3/5

☒ Nur aus sauberer Quelle wiederherstellen

Wiederherstellung ausschliesslich aus **verifiziert sauberen** Backups/Images. Keine Wiederverwendung potenziell kompromittierter Systeme ohne Neuaufsetzen.

☐ Alle Zugaenge erneuern

Passwoerter/Keys/Tokens/Zertifikate rotieren (priorisiert Admin/Dienstkonten). MFA erzwingen.

☒ Verschaerftes Monitoring beim Wiederanlauf

Vor Go-Live zusaetzliche Protokollierung/EDR/Netzwerk-Monitoring aktivieren; Wiederanlauf stufenweise und beobachtet.

☐ Wiederanlauf validieren

Funktion + Sicherheit pruefen (keine Restpersistenz, keine IOC-Kommunikation), bevor der Normalbetrieb freigegeben wird.

☒ 4-Augen-Prinzip fuer Bankdaten

Prozess: IBAN-Aenderungen nur mit telefonischer Rueckbestaetigung; Zahlungen ueber Freigabe-/4-Augen-Workflow.

Ermittlung / Analyse 0/2

☐ Angriffszeitachse rekonstruieren

Erstzugang (Phishing/Credential), Regel-Erstellung, manipulierte Sendungen, Geldfluss. IOCs und Geldwege fuer die Anzeige aufbereiten.

☒ Geldfluss / Mule-Konto

Empfaengerkonto(en), Betraege, Zeitpunkte – fuer Bank & Polizei.

Konten / Betraege / Zeit

Abschluss 1/3

☒ Abschlussbericht erzeugen

Im Tab **Bericht** den Incident-Report exportieren (Zeitachse, Beweise, Kommunikation, Massnahmen).

Start (Szenario-Auswahl)



Lessons Learned

Was hat funktioniert, was nicht? Konkrete Verbesserungen ableiten.

Lessons Learned

☐

Fall abschliessen & Asservate uebergeben

Asservate dokumentiert uebergeben (Chain of Custody schliessen), Fallstatus auf erledigt.

Playbook gefuehrt (BEC)

Forensik-Toolkit

Read-only Triage/Sicherung. Auf den USB-Stick legen, am Zielsystem ausführen.

Windows-Triage Windows (PowerShell, Admin)

Fluechtige + Schluesel-Artefakte eines Windows-Hosts read-only sichern (Prozesse, Netz, Autostarts, Tasks, Dienste, EventLogs, Prefetch) inkl. Hash-Manifest.

Read-only. NICHT herunterfahren. Fuer RAM-Abbild separates Tool nutzen.

► Skript anzeigen (windows-triage.ps1)

[Kopieren](#)[Herunterladen](#)

Linux-Triage Linux (bash, root)

Read-only Triage eines Linux-Hosts (Prozesse, Sockets, offene Dateien, Cron, systemd, Logins, Logs) + Hash-Manifest.

Read-only. NICHT neu starten. Fuer RAM ggf. avml/LiME separat.

► Skript anzeigen (linux-triage.sh)

[Kopieren](#)[Herunterladen](#)

OT-Netzwerk-Capture Linux (bash) – USB-Ethernet

Passiver Netzwerk-Mitschnitt am TAP/SPAN ueber die USB-Ethernet-Karte (pcap) – fuer C2-/OT-Protokollanalyse (104/MMS/GOOSE).

PASSIV. Karte nur an SPAN/TAP, NICHT in OT aktiv einspeisen. Keine IP konfigurieren noetig.

► Skript anzeigen (ot-capture.sh)

[Kopieren](#)[Herunterladen](#)

AD-Triage Windows DC (PowerShell, Admin)

Domain-Controller-Triage bei AD-Kompromittierung: Anmelde-Events (4625/4624/4768/4769/4672), Lockouts, Admin-Gruppenaenderungen, neue Konten.

Read-only. Auf DC ausfuehren. EVTX werden exportiert, nicht geloescht.

► Skript anzeigen (ad-triage.ps1)

[Kopieren](#)[Herunterladen](#)

Bericht & Daten

[Markdown kopieren](#)[.md herunterladen](#)[Fall \(JSON\) exportieren](#)[Timeline CSV](#)[Lagebericht](#)[Daten importieren \(JSON\)](#)[Quick-Paste IOCs](#)

Ingest-Bundles vom Smartphone/Desktop (mobile/desktop-Skripte) hier einlesen.

Incident-Report – Active Directory – Brute Force auf Domain-Admin, dann erfolgreich

- **Organisation:** Beispiel GmbH
- **Sektor:** IT · Identitaet / AD-Kompromittierung
- **Responder:** IR-Team
- **Einstufung:** TLP:AMBER
- **Playbook:** Active Directory – Brute Force auf Domain-Admin, dann erfolgreich
- **Erstellt:** 2026-06-21 08:26
- **Status:** offen

> IDS meldet ~400 fehlgeschlagene Logins gegen einen Domain-Admin in der Produktion, danach ein erfolgreicher.

Fortschritt Massnahmen: 13/26 (50 %)

1. Kurzfassung

IDS meldet ~400 fehlgeschlagene Logins gegen einen Domain-Admin in der Produktion, danach ein erfolgreicher.

2. Zeitachse

- 2026-06-21 08:26 **decision** – Flag status = confirmed _(IR-Team)_
- 2026-06-21 08:26 **comms** – Kommunikation (Geschaeftsleitung / Krisenstab, gemeldet) _(IR-Team)_
- 2026-06-21 08:26 **comms** – Kommunikation (Datenschutz-Aufsichtsbehoerde / DSB, gemeldet) _(IR-Team)_
- 2026-06-21 08:26 **evidence** – Beweis gesichert: DC-Security-Logs (sha256 e3b0c44298fc...) _(IR-Team)_
- 2026-06-21 08:26 **evidence** – Beweis gesichert: NTDS/DCSync-Indikatoren (sha256 e3b0c44298fc...) _(IR-Team)_
- 2026-06-21 08:26 **ioc** – IOC iban: LT121000011101001000 _(IR-Team)_
- 2026-06-21 08:26 **ioc** – IOC ip: 203.0.113.66 _(IR-Team)_

3. Beweismittel & Chain of Custody

M365-Triage

Windows/Cloud (Exchange Online PowerShell)

Microsoft-365-/Exchange-Postfachpruefung bei BEC: Inbox-Rules, Weiterleitungen, Audit-Log, riskante Anmeldungen, OAuth-Grants.

Read-only Abfragen. Erfordert Exchange-Online-/Graph-Module + Admin.

► Skript anzeigen (m365-triage.ps1)

Kopieren

Herunterladen

Mail-Header-Analyse

Plattformunabhaengig (Python 3)

E-Mail-Header aus .eml extrahieren/aufbereiten (Absenderweg, Received-Kette, SPF/DKIM/DMARC, Reply-To-Abweichung) – fuer BEC.

Read-only. Verarbeitet exportierte .eml-Dateien.

► Skript anzeigen (parse-eml.py)

Kopieren

Herunterladen

Beweis-Manifest / Hashing Linux/macOS (bash)

SHA256-Manifest eines Asservat-Ordners erzeugen (Integritaet/Chain of Custody) und spaeter verifizieren.

Read-only.

► Skript anzeigen (evidence-manifest.sh)

Kopieren

Herunterladen

Speicher-Abbild (RAM)

Linux (avml) / Windows (winpmem)

RAM forensisch sichern – zuerst, vor dem Abschalten. Linux per avml, Windows per winpmem (Hinweis).

Fluechtig: vor Abschalten/Trennen. Ausgabe auf USB-Stick, Hash bilden.

► Skript anzeigen (memory-acquire.sh)

Kopieren

Herunterladen

Velociraptor Offline-Collector

Windows/Linux/macOS

Breite, standardisierte Triage mit Velociraptor (offline, ohne Server) – Artefakte als ZIP.

Read-only Collection. Velociraptor-Binary auf den Stick legen.

► Skript anzeigen (velociraptor-collect.sh)

1. DC-Security-Logs (log, Fluechtigkeit: mittel)

- Quelle: — · Methode: EVTX-Export
- SHA256: e3b0c44298fc1c149afb4c8996fb924 ·
Groesse: —
- Ablage: USB:/evidence · Gesichert von: IR-Team · 2026-06-21 08:26
- Custody: 2026-06-21 08:26 gesichert → IR-Team (USB:/evidence)

2. NTDS/DCSync-Indikatoren (log, Fluechtigkeit: mittel)

- Quelle: — · Methode: Analyse
- SHA256: e3b0c44298fc1c149afb4c8996fb924 ·
Groesse: —
- Ablage: USB:/evidence · Gesichert von: IR-Team · 2026-06-21 08:26
- Custody: 2026-06-21 08:26 gesichert → IR-Team (USB:/evidence)

4. Indicators of Compromise (IOC)

- iban: LT121000011101001000 –
Empfaengerkonto (Betrug)
- ip: 203.0.113.66 – C2

5. Kommunikation & Meldungen

- 2026-06-21 08:26 **Geschaeftsleitung / Krisenstab** () – Status: gemeldet
- 2026-06-21 08:26 **Datenschutz-Aufsichtsbehoerde / DSB** () – Status: gemeldet

6. Durchgefuehrte Massnahmen

Erstbewertung – Vorfall oder Fehlalarm? (1/4)

- ☒ Erstbewertung & Quelle dokumentieren
- ☐ Nicht-boeswillige Erklaerung pruefen
- ☐ Einstufung – Vorfall oder Fehlalarm?
- ☐ Weiter mit dem Playbook

Identifikation & Sofortmassnahmen (1/4)

- ☐ Erfolg & Quelle bestaetigen
- ☐ Kompromittiertes DA-Konto sofort sperren
- ☒ Quell-Host isolieren
- ☐ Tier-0 schuetzen

Krisenkommunikation & Meldepflichten (2/4)

- ☒ Geschaeftsleitung briefen
- ☐ Strafanzeige / Polizei (ZAC)
- ☒ Datenschutz / DSGVO pruefen (72 h)
- ☐ Produktion/OT-Verantwortliche warnen

Beweissicherung (2/4)

- ☒ DC-Security-Logs sichern
- ☐ Quell-Host forensisch sichern
- ☒ DCSync/NTDS-Zugriff pruefen
- ☐ AD-Aenderungen sichern

Eindaemmung (2/3)

- ☒ KRBTGT zweimal zuruecksetzen
- ☐ Privilegierte Konten bereinigen
- ☒ Quelle blocken / Spray stoppen

Bereinigung (1/2)

- ☐ Persistenz jagen & entfernen
- ☒ Kompromittierte Hosts neu aufsetzen

Kopieren
Herunterladen

UAC - Unix-like Artifacts Collector

Linux/macOS/Unix

Standardisierte Live-Triage fuer Linux/Unix/macOS (Logs, Persistenz, Prozesse) als Archiv.

Read-only. UAC (uac-*/uac) auf den Stick legen.

► Skript anzeigen (uac-collect.sh)

Kopieren
Herunterladen

Super-Timeline (plaso)

Linux (plaso) / Sleuthkit

Forensische Super-Timeline aus einem Mount/Image (plaso log2timeline -> psort CSV) bzw. Dateisystem-Timeline (Sleuthkit).

Read-only auf Image/Mount (ro). Rechenintensiv.

► Skript anzeigen (make-timeline.sh)

Kopieren
Herunterladen

CyberChef (offline)

Browser / offline (auch Smartphone)

CyberChef einmalig auf den Stick holen – danach OFFLINE im Browser: Base64/Hex/Gunzip dekodieren, JWT zerlegen, IOCs defangen, Magic-Erkennung, Hashes. Ideal zur schnellen Analyse am Fold 5 ohne Internet.

Read-only Analyse im Browser (eine HTML-Datei). Einmal mit Internet holen, dann offline nutzbar: tools/cyberchef/CyberChef.html oeffnen.

► Skript anzeigen (fetch-cyberchef.sh)

Kopieren
Herunterladen

Forensik-Toolkit

Sicherer Wiederanlauf (2/5)

- ☐ Nur aus sauberer Quelle wiederherstellen
- ☒ Alle Zugaenge erneuern
- ☐ Verschaerftes Monitoring beim Wiederanlauf
- ☒ Wiederanlauf validieren
- ☐ Tiering & MFA einfuehren

Ermittlung / Analyse (1/2)

- ☒ Zeitachse & Reichweite
- ☐ Vollstaendigkeit pruefen

Abschluss (1/3)

- ☒ Abschlussbericht erzeugen
- ☐ Lessons Learned
- ☐ Fall abschliessen & Asservate uebergeben

7. Offene Aufgaben

keine offenen Aufgaben

Erzeugt mit IR-Pilot · 2026-06-21 08:26 · TLP:AMBER

Bericht & Daten-Import

